

STUDENT	HASSANI Mohammad Salem	INSTRUCTOR	Asen Grozdanov
DATE	January 9, 2026	COURSE	Managing Vulnerabilities

EXERCISE 1 — CVE RECONNAISSANCE

The following CVE was selected for in-depth reconnaissance due to its critical severity, confirmed CISA KEV status, and relevance to perimeter security infrastructure:

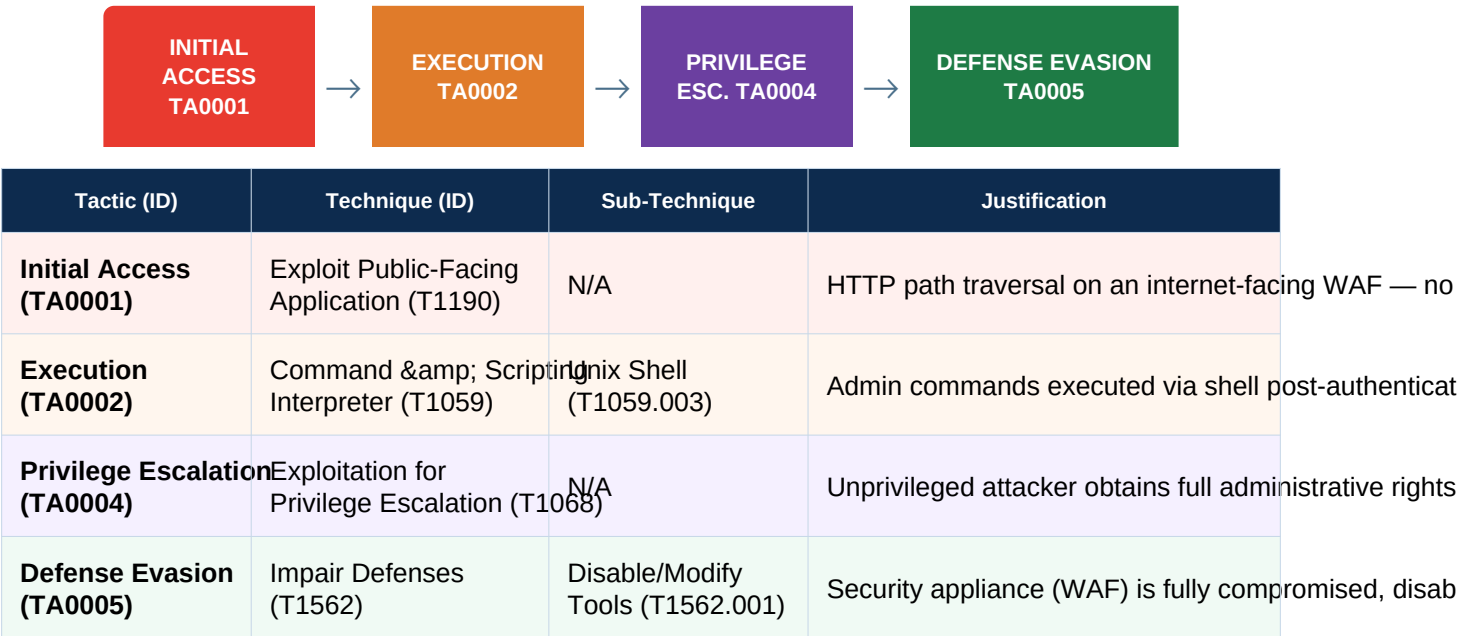
Field	Details
CVE ID	CVE-2025-64446
Product	Fortinet FortiWeb 7.0 – 8.0
CVSS v3.1	9.8 — CRITICAL
Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Description	Relative Path Traversal leading to unauthenticated admin command execution
CWE	CWE-23: Relative Path Traversal
CISA KEV	YES — confirmed exploited in the wild

CVSS Vector Breakdown

Metric	Value	Meaning	Implication
Attack Vector (AV)	Network (AV:N)	Exploitable over the internet	Public-facing WAF is directly reachable
Attack Complexity (AC)	Low (AC:L)	No special conditions required	Reliable, repeatable exploitation
Privileges Required (PR)	None (PR:N)	No credentials needed	Unauthenticated attack chain
User Interaction (UI)	None (UI:N)	No victim action required	Fully automated exploitation possible
Confidentiality (C)	High (C:H)	Full data disclosure	TLS traffic interception / credential theft
Integrity (I)	High (I:H)	Full data modification	WAF rules can be altered or disabled
Availability (A)	High (A:H)	Full service disruption	WAF can be taken offline

EXERCISE 2 — MITRE ATT&CK; MAPPING

CVE-2025-64446 maps to a four-stage adversary kill chain in the MITRE ATT&CK Enterprise Matrix. The vulnerability enables an attacker to progress from initial network access through to full privilege escalation and defense evasion:



Threat Intelligence Sources: CISA KEV (confirmed active exploitation) + GitHub PoC (WatchTowr Labs). Mapping was validated using the MITRE ATT&CK Navigator.

EXERCISE 3 — DEFENSIVE CONTEXT

ATT&CK; Mitigations

Mitigation ID	Name	Application to CVE-2025-64446
M1030	Network Segmentation	Isolate the WAF into a dedicated DMZ segment; restrict management access to internal
M1048	Application Isolation & Sandboxing	Limit process privileges on the FortiWeb host to reduce post-exploitation lateral mov
M1051	Update Software	Upgrade to FortiWeb 8.0.2 — the only complete mitigation; no workaround is availabl
M1016	Vulnerability Scanning	Schedule continuous authenticated scans to detect unpatched FortiWeb instances b

Detection Approaches

Three complementary detection layers should be deployed to identify exploitation attempts and post-compromise activity:

Layer	Tool / Source	Detection Logic	ATT&CK; Coverage
1 — Web Logs	SIEM / WAF logs	Alert on requests containing "../" path sequences. Sigma rule: http.uri contains "../"	T1190
2 — IDS / IPS	Snort / pfSense	HTTP anomaly signatures for malformed path traversal patterns and unusual admin en	T1190, T1059
3 — Telemetry	EDR / Process monitoring	Alert on new child processes spawned from the WAF service (unexpected shell	T1059.003, T1068

Sample Sigma Detection Rule:

```
title: FortiWeb Path Traversal Attempt
status: experimental
logsource:
  product: fortinet
  category: webserver
detection:
  selection:
    http.uri|contains: "../"
  condition: selection
falsepositives:
  - Legitimate path normalization
level: high
```

Reflection

Insight	Detail
Key Finding	ATT&CK mapping revealed a complete edge-device kill chain (T1190 → T1059 → T1068 → T1562).
Framework Limitation	MITRE ATT&CK does not cover zero-day vulnerabilities prior to public disclosure. Threat hunting must identify these gaps.
Professional Application	Plan to hunt for publicly-exploited perimeter vulnerabilities first. The T1190 → T1068 chain represents the high-risk path.
Tools Used	NVD (CVE details) · MITRE ATT&CK Navigator (kill chain visualisation) · FIRST CVSS Calculator